STIG Audit Basic User Guide

Getting started with the IOS and IOS XE switch auditor

Use this guide to open the Basic application, prepare the expected settings for your site, run a read-only assessment, and review encrypted TXT reports or CKL checklists. Basic writes new reports as .sapenc files; it opens supported text reports in memory and creates a readable, unencrypted copy only when you explicitly export one. No Python installation is needed for the supplied Windows executable. The window retains the name STIG Audit Pro Basic; this package opens the Basic five-tab application.

What the app does

A STIG is a Security Technical Implementation Guide: a set of security requirements. This app runs selected checks against Cisco switch information. IOS and IOS XE are the two Cisco operating-system choices. L2 means Layer 2 switching controls; NDM means Network Device Management controls. A profile is a file containing the settings your organization expects. A CKL is a checklist file you can review in your organization's STIG Viewer workflow.

The package contains IOS L2 with 22 checks, IOS NDM with 35, IOS XE L2 with 22, and IOS XE NDM with 42. Nine entries are manual presets. The app reports what its configured checks find; a preset or pattern match needs assessor review before it becomes a final compliance decision.

1 Extract and start

1. Save the ZIP to a Windows computer and choose Extract All. Put the extracted folder somewhere you can write, such as Documents. Do not start the app from inside the ZIP.
2. Keep the entire folder together. Double-click START BASIC AUDIT.cmd, or open Application and double-click STIG Audit Basic.exe. Keep Application_internal beside the executable; it contains the Python runtime and libraries. On first launch, create an audit-data passphrase; later launches require that same passphrase to unlock existing reports. Keep it in an approved password manager because there is no reset path.
3. The app opens with Audit, Results, Summary, License, and Help tabs. No license is needed for one device per audit. You can keep many devices in the list and choose which one to run. A signed license can permit a larger batch and specifies its enabled features and expiration.
4. The app creates Documents\STIG Audit Pro Basic\Workspace under the current Windows user. Default output and saved template path settings go there. The six CKL templates stay in the package's Checklist Templates folder.

2 Try a demonstration first

1. On Audit, select IOS XE, L2 + NDM, and Sample outputs. Use the base_iosxe_access profile.
2. Leave the example target 192.0.2.10 or import Examples\devices.csv. These are demonstration addresses. The last address segment 26 selects the noncompliant sample; other addresses select the compliant sample set. No connection is made in Sample outputs mode. Click Select devices and choose one example address, then Use selection. The other addresses stay in your list.
3. Leave TXT report selected and clear CKL checklist for this first demonstration. Select an empty output folder, such as a new Demo Results folder.
4. Click Start Audit and watch the Audit result card or Results progress log. A completed run shows the number and full paths of encrypted .sapenc files. Click Open output folder to locate them, then View latest protected report to read the most recent text report in Basic. You can also use Results > Open protected report.
5. Sample output is for IOS XE only. Selecting IOS with Sample outputs displays an error. Use Live SSH for an IOS switch. Sample results can include findings because the editable baseline has changed since the samples were written.

3 Gather information for a real assessment

- The management IP addresses or resolvable hostnames of the switches you are authorized to assess.
- An SSH username and password with access to the required show commands. Add an enable secret only if the device needs it. Live SSH uses port 22. One set of credentials applies to the whole run; use separate runs for different credentials.
- The correct platform: IOS XE or IOS. Ask the network owner or check show version. Split mixed-platform switches into separate runs.
- Approved site values: VLAN numbers, upstream CDP names, management ACL and subnets, RADIUS group and server names/IPs, TACACS group, logging and NTP servers, approved software versions, password policy name, and management session maximum.
- A blank checklist matching the platform and L2, NDM, or L2 + NDM selection. Six blank templates are included in Checklist Templates. Confirm their benchmark/release with your assessor before using them.

4 Prepare the profile

Profiles are editable YAML text files in Application\data\profiles. IOS XE selects base_iosxe_access; IOS selects base_ios_switch_access. The Audit tab displays the exact profile and check paths currently in use. The shipped base values preserve the working installation and are not universal defaults.

1. Close the app before adding or renaming a profile. Copy the correct base YAML to a new file such as my_site_ios.yaml. Set profile_name to the same name without .yaml. Keep inherits: null for a complete independent copy.
2. Open the new file in a plain-text editor. Replace only the values with those approved for your site. Preserve indentation with spaces and list entries marked by a hyphen. Do not enter SSH passwords or secrets in the profile.
3. Reopen the app. Select the platform first, then your site profile. Changing the platform resets the profile selection to that platform's base.
4. Check the displayed Site profile path before every run. The same profile is applied to every switch in that run. Use separate runs when devices require different policies.

- unused_vlan: VLAN reserved for unused access ports. Ask the network owner for the approved number.
- native_vlan: Approved native VLAN number on trunks.
- management_vlan: Management SVI VLAN used to discover the address written into the checklist asset. The protected report filename identifies the complete audit target.
- dhcp_snooping.vlans: User VLAN numbers expected to have DHCP snooping configured.
- arp_inspection.vlans: User VLAN numbers expected to have Dynamic ARP Inspection configured.
- root_guard.upstream_switches: Exact upstream core/distribution Device IDs from show cdp neighbors detail. Short names and fully qualified names are matched. These links are exempt from Root Guard.
- management_access.acl_name: Name of the ACL applied inbound to VTY management lines.
- management_access.networks: Approved source networks as network_address and subnet_mask. Use an ordinary subnet mask, not an ACL wildcard mask.
- endpoint_authentication.radius_group: AAA RADIUS server group name as configured on the switch.
- endpoint_authentication.radius_servers: List of required radius server names; use the configuration names, not necessarily DNS hostnames.
- endpoint_authentication.radius_server_addresses: Mapping of each listed RADIUS configuration name to its expected IPv4 address.
- variables.logging_servers: Exact IP addresses or hostnames following logging host in the configuration. List at least two approved destinations.
- variables.ntp_servers: Exact IP addresses or hostnames following ntp server. List at least two approved sources.
- variables.supported_ios_versions: Exact approved IOS release strings from show version. The shipped IOS value is 15.2(7)E14; the organization must maintain the list.

- variables.supported_iosxe_versions: Exact approved IOS-XE release strings from show version. The shipped value is 17.12.08; the organization must maintain the list.
- variables.local_password_policy: Name of the aaa common-criteria policy referenced by local user configuration.
- variables.tacacs_group: TACACS+ server group name used by the default login method list.
- variables.max_concurrent_management_sessions: Organization-approved maximum concurrent management sessions, a positive integer.
- trunk_policy.additional_pruned_vlans: Additional VLAN numbers forbidden on trunks, where referenced by a check.

Example only: a RADIUS server named RADIUS-SERVER-1 has an address entry under endpoint_authentication.radius_server_addresses with exactly the same name. NTP and logging lists use the value visible in the switch configuration; an IP address and a hostname are not automatically treated as equivalent. A syntactically valid file can still describe the wrong site.

5 Add devices and select the assessment

1. Replace the example address in the device box. Put one IP or hostname on each line. Commas, semicolons, and tabs also separate entries.
2. Alternatively, click Import CSV/TXT. A TXT file has one address per line. A CSV must have a header named ip, address, host, or hostname; otherwise its first column is used and the first row is still treated as a header. Review the import message for duplicates and invalid entries.
3. Click Select devices. Choose one device in Free Basic, or a batch up to the limit shown for your signed license. Click Use selection. Select all is available only when the entire list fits the limit. Removing a selected address clears that selection; the app requires you to choose again instead of silently auditing another device.
4. Choose IOS XE or IOS, then L2, NDM, or L2 + NDM. Choose Live SSH for real devices. Enter the username, password, and optional enable secret.
5. Select the site profile and verify the paths printed below the selectors. The app reloads check and profile files when you press Start Audit, so saved edits apply to the next run.

6 Choose the checklist and output

1. For CKL output, use the IOS XE or IOS template tab that matches the platform selector. Click Browse beside the selected family and choose its file from Checklist Templates.
2. L2 + NDM requires the combined L2 + NDM template slot. Selecting the two separate templates does not substitute for a combined template.
3. Browse displays and remembers the selected CKL file path. The app reads the file directly. The six supplied CKLs are selected by default from this package's Checklist Templates folder. Keep custom templates at their selected locations.
4. Click Choose output folder and confirm the displayed location. Both TXT and CKL reports are saved there as encrypted .sapenc files; the default is Workspace\Completed CKLs. Select at least one output format. Open output folder opens the selected location in File Explorer.
5. Filenames include a Windows-safe identifier for the complete target and a run identifier, so devices with the same final IP octet receive distinct names. Existing protected reports are not intentionally replaced. For clear separation of assessment evidence, use a new output folder for each run.

7 Run and review

1. Click Start Audit. The Audit result card shows run status, device counts, encrypted file count, and the selected output folder. Results keeps the progress log, device outcomes, and paths of files created. Confirm the reported file count in the output folder before treating the run as saved.
2. Leave the application open while it works. Cancel requests cancellation of remaining work; wait for the run to end and review its final status before starting again or closing the application.

3. Completed means all selected devices produced the requested protected output. Partial audit means at least one device did not complete; Audit failed means none completed or no requested output was saved. The result card and Results log identify failures and files that exist. Use Open output folder to inspect the actual files and View latest protected report to read the latest supported text report in Basic. Never treat a failed device as assessed.
4. Investigate Open, Error, Not Reviewed, and Skipped items. Review every manual preset and Not Applicable decision. The check reference explains the exact current logic and needed site values for each V number.
5. To use a CKL in STIG Viewer or another approved tool, select its .ckl.sapenc file under Results > Export readable copy. Confirm the warning and save the resulting unencrypted .ckl in an approved location. Complete assessor comments and manual status decisions there. Basic does not provide an in-app finding review editor.

- NotAFinding: The implemented test passed, or a manual preset assigns a pass. Verify the evidence and site assumptions.
- Open: A required condition failed, a forbidden condition was found, or a preset assigns Open.
- Not_Applicable: The check is exempt under its configured condition or preset; confirm applicability.
- Not_Reviewed: No final determination was made. Some checks deliberately use this even when their pattern test passes or fails.
- Error: Required output was missing or evaluation failed. It is not a passing result.
- Skipped: The item was not evaluated. Check collection and cancellation messages.

CKL has no Error or Skipped status, so the writer converts those to Not_Reviewed. A template may contain STIG requirements beyond the 121 implemented checks; unmatched blank entries remain Not_Reviewed. Open the protected TXT report in Basic for the original application status and explanation.

7A Create an overall summary

1. Complete an audit, then open Summary. It covers only the devices selected in the current run; earlier runs are separate.
2. Filter details by status, CAT, switch, or STIG family. Preview the selection. Choose PDF with charts, HTML with charts, CSV details, or several formats, then click Export summary. These summary files are also encrypted .sapenc files in the selected output folder.
3. The overview charts and per-switch CAT table describe the entire run; filters change detailed rows. A device with no check results is shown as Unassessed. Basic can preview protected HTML and CSV as text; to view a protected PDF in a PDF reader, deliberately export a readable, unencrypted copy. See 06_Overall_Summary_Reporting.txt for counts and limitations.

8 Find files and solve common problems

- Editable checks: Application\data\checks. Editable profiles: Application\data\profiles. Change these visible files, not _internal\data or the archival Source copy.
- Default templates: Checklist Templates beside Application in the extracted package. Selected paths are remembered in Documents\STIG Audit Pro Basic\Workspace\template_paths.json. Default encrypted results: Workspace\Completed CKLs. The output field on Audit shows the folder actually selected for the current run.
- Configuration not ready: review the named YAML file, indentation, and required values. Start again after saving a correction.
- Authentication failure: verify username, password, privilege level, and optional enable secret. Timeout: verify the management address, DNS, routing, SSH service, and network access.
- CKL template required: browse a matching file into the selected platform/family slot. A wrong template can leave findings unmapped; check the completed V numbers.
- No report or partial results: check the Audit result card and Results log for the exact output path, file count, device failures, or cancellation. Use Open output folder to verify the .sapenc files that exist. Correct the cause and rerun affected devices into a fresh folder. See 08_Report_Output_Troubleshooting.md.

- Sharing a problem: send the platform/family, profile name, V number, expected result, actual result, and a redacted excerpt from a deliberately exported readable copy. Handle that copy as unencrypted sensitive data. Do not send SSH credentials or the audit-data passphrase.

9 Import and manage a license

Free Basic permits one selected device in each audit, with IOS and IOS XE L2/NDM checks and TXT/CKL output. You may audit a different device in the next run. The limit is the size of one selected batch, not the number of addresses you may keep in the box. Basic runs one audit job at a time within its window.

1. Obtain a signed .license.json file from the application owner. Do not edit its contents; any change invalidates the signature.
2. Open License and click Import / Replace License. Browse to the signed file. The app verifies the signature, product, fields, and expiration before saving it. An invalid replacement leaves an existing license in place.
3. Read the customer, expiration in UTC, effective device limit, and enabled features on License. A license must enable Multi-device audits as well as a limit above one to allow a batch. Disabled check or report features must be cleared on Audit before starting.
4. Return to Audit, click Select devices, choose a permitted batch, and click Use selection. The full list is retained. A batch exceeding the current limit is rejected, not silently shortened.
5. The app checks the license before collection and again before writing reports. Status refreshes about every 30 seconds, and Refresh License updates it immediately. Importing a replacement is blocked during an active audit.
6. A missing, invalid, or expired license returns the app to Free Basic. Existing reports and the listed devices remain. If a license expires during a multi-device run, export is blocked; import a renewed license and rerun, or rerun one selected device in Free Basic. Partial work from that blocked run is not saved for later export.

The License tab shows the exact saved license location, normally under the Windows user's Local AppData/STIG Audit Pro Basic folder. Basic stores it separately from Pro. There is no online activation or remote license lookup. Contact the owner for a renewed file or different features. Existing signed licenses remain compatible when their signing public key is bundled and their expiration is valid. See 03_Basic_Licensing.md for operator license guidance.

Tester notes for this release

This guide describes the Basic report-encryption and result-status workflow. No live-device assessment is claimed by this document. Before operational use, confirm the selected benchmark, site profile, device evidence, and the current security verification record. Nine checks remain manual presets and require assessor review.